



DAY 2

How Risky Are You?

Passive Exploitation

Threat Modeling

Risk Register Construction

North South University

Session Roadmap

RISK ASSESSMENT

WHY SCORING RISK BEFORE AN INCIDENT
IS NOT OPTIONAL

01

05

LAB PART 1:

Passive Exploitation (Hacker Perspective)

PASSIVE EXPLOITATION

HOW ATTACKERS GATHER INTELLIGENCE
WITHOUT TOUCHING THE TARGET

02

06

LAB PART 2:

Risk Register Construction (Auditor
Perspective)

BUILDING THE ASSET INVENTORY

WHY WHAT YOU DON'T KNOW WILL BE
EXPLOITED

03

08

TEAM TASK & EVALUATION

STRIDE THREAT MODELING

TRANSLATING TECHNICAL FINDINGS INTO
BUSINESS RISK

04

BUILDING THE ASSET INVENTORY

**WHY WHAT YOU DON'T KNOW WILL BE
EXPLOITED**

CROWN JEWELS EXERCISE

WHAT ARE CROWN JEWELS?



The **3 most critical assets** whose compromise could **severely damage** or **end the business**.

1 [Crucial Data] **2** [Key System] **3** [Critical Process]

WHY IMPORTANT?



Highest security priority:
Focus on defensive resources.



Strongest protection:
Implement multi-layered security controls.



Fastest incident response:
Minimize downtime and data loss.



Highest risk scores in the risk register: Elevated visibility for board-level oversight.

Identify. Prioritize. Protect.

GUIDE TO IDENTIFYING AND SECURING YOUR CROWN JEWELS

IDENTIFY CROWN JEWELS (Ask These Questions)

WHICH SYSTEMS GENERATE REVENUE?



Identify key financial and payment-related applications.

WHICH ASSETS CONTAIN SENSITIVE



Look for customer databases and intellectual property.

WHICH SYSTEMS ARE ESSENTIAL FOR OPERATIONS?



Pinpoint infrastructure necessary for day-to-day work.

WHICH COMPROMISE WOULD CAUSE MAXIMUM IMPACT?



Consider severe reputational or legal fallout.

COMMON EXAMPLES & BUSINESS IMPACT



Customer Database

**DATA BREACH,
LEGAL PENALTIES**



Authentication System

**UNAUTHORIZED ACCESS
TO ALL SYSTEMS**



**Financial/
Payment System**

**REVENUE LOSS AND
OPERATIONAL OUTAGE**

These examples illustrate potential crown jewels based on impact.

SECURITY FOCUS FOR CROWN JEWELS



- MFA and strict access control



- Continuous monitoring



- Network segmentation



- Backup and disaster recovery



- Immediate patching and remediation

PASSIVE EXPLOITATION

**HOW ATTACKERS GATHER INTELLIGENCE
WITHOUT TOUCHING THE TARGET**

PASSIVE EXPLOITATION - GATHERING INTELLIGENCE WITHOUT TOUCHING THE TARGET

Anonymous FTP Login



Default configurations leave sensitive files world-readable.

```
ftp [Target_IP]  
user: anonymous / any password
```

STRIDE

Information Disclosure

exposure of company backups, config files

Risk Score: $L:4 \times I:4 = 16$ (Critical)
Trivially exploitable, high business impact

Directory Brute-forcing



Hidden folders are not hidden from attackers.

```
gobuster dir -u http://[Target_IP]/  
-w /usr/share/wordlists/dirb/common.txt
```

Goal

Find `/phpMyAdmin`, `/config`,
`/backup`, `/admin`
paths exposed by default configurations

Nikto Automated Web Scan



Run the moment a web server is found.

```
nikto -h http://[Target_IP]/
```

Output

20+ vulnerabilities including
OSVDB IDs and CVE references
each maps to a known exploit

Enum4linux: SMB Username Harvesting

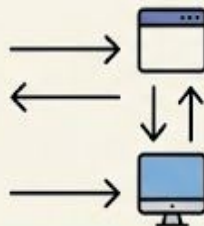
No Password Required



```
enum4linux -a [Target_IP]
```

How Usernames are harvested

Uses null sessions and
protocol queries (like MSRPC)
to request domain user
lists from SMB.



STRIDE: Information Disclosure

Employee usernames become
phishing/brute-force target lists.

SQL Injection Authentication Bypass

Why Unvalidated Input allows Privilege Escalation



%' OR '1'='1

Username

Password



The payload makes the SQL WHERE clause
always true

(... WHERE UserID = '% ' OR '1'='1' ...),
forcing the query to return all rows,
effectively bypassing password checks.

STRIDE: Elevation of Privilege

Attacker gains admin access without a
valid password.

RISK ASSESSMENT

**WHY SCORING RISK BEFORE AN INCIDENT IS
NOT OPTIONAL**

WHAT IS RISK?

DEFINITION

Risk is the combination of two key elements



LIKELIHOOD >>>

How **likely** an incident is to happen

LOW  HIGH

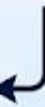
IMPACT  

How **severe** the damage would be

LOW  HIGH

RISK FORMULA

$$\boxed{\text{RISK}} = \text{LIKELIHOOD} \times \text{IMPACT}$$

 $\boxed{\text{RISK}} = \text{PB} \uparrow \text{LIKELIHOOD} \times \text{IMPACT}$ 

RISK RATING


Low Medium High

4x4 RISK MATRIX

PROBABILITY	Probable	4 Moderate	8 Major	12 Severe	16 Severe
	Possible	3 Minor	6 Moderate	9 Major	12 Severe
	Unlikely	2 Minor	4 Moderate	6 Moderate	8 Major
	Rare	1 Minor	2 Minor	3 Minor	4 Moderate
		Low	Medium	High	Very High
IMPACT					



Rating	Score Range	Business Meaning	Response Urgency
Critical	12–16	Existential threat to the business	Immediate - fix within 72 hours
High	8–11	Significant operational or financial damage	Fix within 2 weeks
Medium	4–7	Disruption or compliance exposure	Fix within 30 days
Low	1–3	Minor inconvenience or theoretical risk	Accept or schedule

FOUR OPTIONS FOR RISK TREATMENT

1 MITIGATE (REDUCE RISK)

- **Why Exist:** Reduce Likelihood or Impact
- **When Use:** For significant, manageable risks where controls can be applied.
Example: Patch a vulnerability.

2 TRANSFER (SHIFT RISK)

- **Why Exist:** Shift Financial Risk to Third Party
- **When Use:** When a specific high financial impact risk cannot be easily mitigated.
Example: Cyber Insurance, Managed Service Provider

3 ACCEPT (DOCUMENT DECISION)

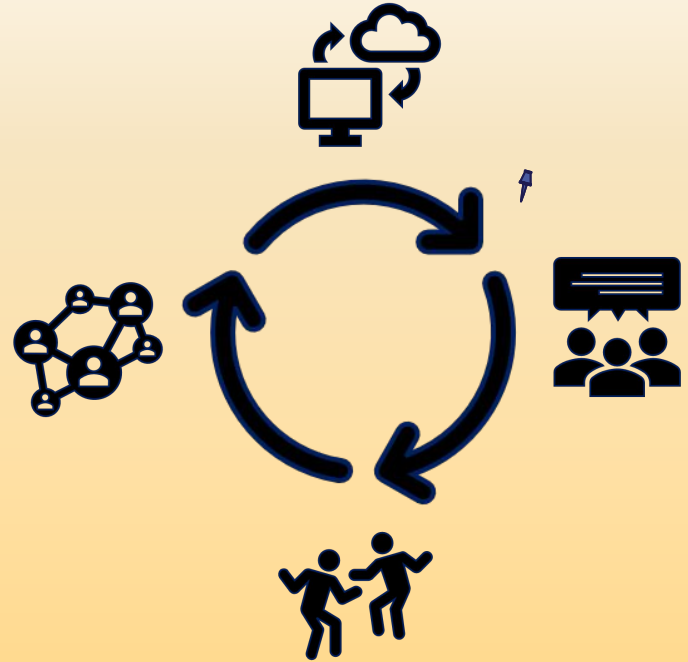
- **Why Exist:** Formal Decision that Cost to Fix >
- **When Use:** For small or acceptable risks where mitigation is not cost-effective.
(Must be Signed by Management)

4 AVOID (ELIMINATE ACTIVITY)

- **Why Exist:** Stop the Risky Activity Entirely
- **When Use:** When a service is not needed or the hardware is obsolete and too risky to keep.
Example: Shut Down Service, Decommission Hardware

THREAT MODELING

TRANSLATING TECHNICAL FINDINGS INTO BUSINESS RISK



WHAT IS THREAT MODELING?

- What are we building? (Your system)
- What could go wrong? (The threats)
- What are we going to do about it? (The fix)



Figure: Steps to Threat Modeling

THREAT MODELING METHODOLOGIES



STRIDE: A simple checklist used to find what can go wrong in a system's design.



PASTA: A risk-focused plan that mimics real-world attacks to see how they hurt a business.



TRIKE: A management tool used to decide how much risk a business is willing to accept for its assets.



VAST: Automated system designed to keep up with fast-moving, modern software teams.



DREAD: A math-based rating system used to score and prioritize which threats to fix first.



OCTAVE: A business-focused strategy that protects the company's most important information assets.



What is STRIDE?





STRIDE

S

Spoofing mean Pretending to be someone else; the goal is **Authentication** (Verify identity).

R

Repudiation mean Denying an action took place; the goal is **Non-repudiation** (Proof of action).

D

Denial of Service mean Crashing/blocking a system; the goal is **Availability** (Keep systems running).

T

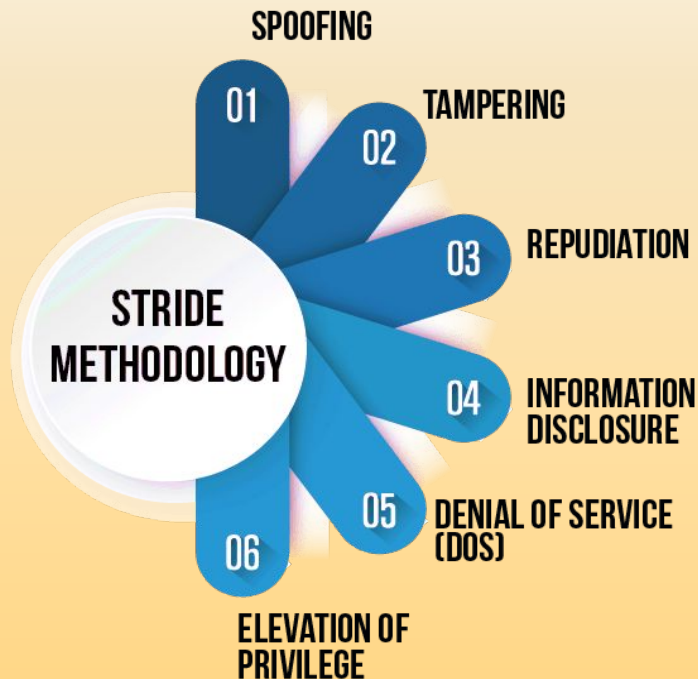
Tampering mean Modifying data or code; the goal is **Integrity** (Ensure data is accurate).

I

Information Disclosure mean Leaking private data; the goal is **Confidentiality** (Keep data private).

E

Elevation of Privilege mean Gaining unauthorized power; the goal is **Authorization** (Permissions).



STRIDE Category	Attack Example	Business Impact	Technical Indicator
Spoofing	Fake vendor email, fake login page	Financial fraud, credential theft	No email SPF/DKIM, no MFA
Tampering	Modified invoice records, altered logs	Legal liability, financial loss	No integrity monitoring, no audit trail
Repudiation	Staff denies action, no logs to prove otherwise	Fraud goes unpunished, audit fails	Logging not enabled, logs not retained
Information Disclosure	Exposed database, anonymous FTP	Customer data theft, regulatory fine	Enum4linux findings, open directory listing
Denial of Service	Ransomware encrypts systems, DDoS kills website	Operational shutdown, revenue loss	No backups, no redundancy
Elevation of Privilege	Admin account misuse, SQLi bypass	Full system takeover	Nikto admin panel, SQLi vulnerability



Hands-on Activity



Part 1: Risk Register Construction (Auditor Perspective)

- Asset Inventory: document minimum 10 assets from the MSME profile (hardware, software, data, people, processes)
- Crown Jewels: identify the 3 assets whose loss would be catastrophic - justify the selection
- Apply STRIDE: for each asset, identify the top applicable threat category and map to a technical finding
- Score every threat: Likelihood × Impact (1–4 scale) - at least one finding must reference a Nikto or Enum4linux result
- Complete the Risk Register: minimum 10 rows with treatment decision and assigned owner
- Top 3 Critical Risks: present with technical justification - why is the score correct?



Lab Activity

Instructions

Part 2: Passive Exploitation (Hacker Perspective)

- Run Anonymous FTP login - document every accessible file and directory
- Run Gobuster directory scan - list every hidden path discovered, classify the exposure risk
- Run Nikto on the target - record every OSVDB ID and CVE reference found
- Run Enum4linux - extract all usernames and share names; assess phishing/brute-force potential
- Run SQL Injection bypass - confirm authentication can be bypassed without credentials

Thank You